

README: KIT INTEGRAL ENCUESTA CIBERSEGURIDAD MAGERIT-NIS2-ENS

Guía de Inicio Rápido y Descripción General

Versión: 2.0 | **Fecha:** Enero 2026 | **Audiencia:** CISOs, Consultores, Auditores

Idioma: Español | **Actualización:** Anual (por cambios regulatorios)

¿QUÉ ES ESTE KIT?

Este es un **conjunto profesional y descargable de documentos** (7 archivos .md) que operacionaliza:

- **MAGERIT v3** (metodología española análisis riesgos)
- **Directiva NIS2** (regulación ciberseguridad UE)
- **ENS RD 311/2022** (esquema nacional seguridad España)
- **NIST CSF 2.0** (marco internacional flexible)
- **ISO 27001:2022** (estándar SGSI certificable)

Todo en **una encuesta integral de 75+ preguntas** que evalúa madurez ciberseguridad organizacional y genera:

- ✓ Índice Global de Madurez (IGM %) con nivel CMM L0-L5
- ✓ Identificación brechas regulatorias (NIS2, ENS)
- ✓ Cuantificación riesgos residuales (€ ALE/año)
- ✓ Análisis ROI de inversiones seguridad
- ✓ Recomendaciones priorizadas con presupuesto

7 ARCHIVOS DEL KIT

1. ENCUESTA INTEGRAL (01-encuesta-integral.md)

Contenido: 75 preguntas estructuradas en 10 bloques

Bloque	Tópico	# Preguntas	Nivel Técnico
1	Gobernanza & Estrategia	4	Ejecutivo
2	Gestión Riesgos MAGERIT MAR	8	Técnico alto
3	Indicadores & Métricas	7	Técnico medio
4	Vulnerabilidades & Penetesting	9	Técnico alto
5	SIEM & Monitorización	12	Técnico alto
6	Capacitación & Concienciación	9	Operacional
7	Resiliencia & Continuidad	10	Técnico medio
8	Cumplimiento Normativo	10	Legal/Compliance
9	Incidentes & Respuesta	6	Operacional
10	Madurez General & Contexto	4	Ejecutivo
TOTAL	-	75	Mixto

Escala: Likert 1-5 (L1 Ad hoc → L5 Optimizado)

Tiempo: 45-60 minutos cumplimentación

Formato: Markdown, imprimible o digital

Usos:

- Diagnóstico madurez organizacional
- Auto-evaluación SGSI
- Preparación auditoría NIS2/ENS/ISO 27001
- Benchmarking interno (año a año)

2. GUÍA METODOLÓGICA (02-guia-metodologica.md)

Contenido: Instrucciones detalladas administración encuesta

Sección	Contenido	Lectura
1. Propósito & Scope	Qué mide, a quién va dirigida	5 min
2. Pre-Encuesta	Preparación, respondentes, briefing	10 min
3. Administración	Opciones (digital/colaborativa/mixta)	15 min
4. Análisis Respuestas	Cálculos IGM, brecha, ROI	15 min
5. Generación Informe	Estructura, visualizaciones, redacción	20 min
6. Sesión Feedback	Presentación resultados, plan acción	15 min
7. Iteración & Seguimiento	Re-evaluación, dashboard, benchmarking	10 min
8. Troubleshooting	FAQ, resolución discrepancias	10 min
9. Ética & Confidencialidad	Privacidad datos, honestidad	5 min
TOTAL	-	100 minutos

Paso a paso:

1. Identificar respondentes (3-5 personas: CISO, TI, Legal, RR.HH.)
2. Briefing 30 min explicar metodología
3. Responder encuesta (45-60 min, individual o colaborativo)
4. Análisis automático con Excel (60-90 min)
5. Generar informe ejecutivo (60 min)
6. Sesión feedback + plan acción (90 min)

Total proyecto: 4-5 horas comienzo a fin

3. NARRATIVA EXPLICATIVA (03-narrativa-explicativa.md)

Contenido: Fundamentos teóricos & contexto regulatorio

Capítulos:

1. **Introducción:** ¿Por qué evaluar ciberseguridad?
2. **Fundamentos Teóricos:** CMM, MAGERIT, NIST, ENS, NIS2, ISO 27001
3. **Indicadores & Métricas:** GQM, FAIR/ALE, 46 métricas INCIBE
4. **Conexión Encuesta-Frameworks:** Mapeos, proporcionalidad
5. **Casos de Uso:** Interpretación resultados (asimétrica, startup, banco)
6. **Limitaciones & Excepciones:** Contexto sectorial
7. **Próximos Pasos:** De teoría a acción

Audiencia: Ejecutivos, auditores, curiosos

Lectura: 15-20 minutos

Referencia: Consultar si hay dudas interpretación

4. MAPEO NORMATIVO (04-mapeo-normativo.md)

Contenido: Tabla completa pregunta ↔ Requisito regulatorio

Estructura:

- **Columnas:** # Pregunta | Texto | Riesgo L1-L2 | Mapeo NIS2 | Mapeo ENS | Mapeo ISO 27001 | Mapeo NIST | Observaciones
- **Filas:** Una por cada pregunta encuesta (75 total)

Ejemplo:

P1.1.1.1 | ¿Política ciberseguridad formalizada?
Riesgo: ALTO
NIS2: Art 17 (Governance)
ENS: Org.1
ISO 27001: A.5.1
NIST: GO-GV
Observación: Requisito base, auditado anualmente

Usos:

- Validar conformidad regulatoria pregunta por pregunta
- Calcular % conformidad NIS2/ENS/ISO
- Argumentar ante autoridades auditoría
- Identificar gaps legislativos

Matrices incluidas:

- **Matriz Conformidad:** % cumplimiento por requisito NIS2
- **Matriz Riesgo Regulatorio:** Nivel acción recomendada por % conformidad
- **Control Validation:** Verificar evidencia documentada de respuestas

5. PLANTILLA EXCEL (05-template-gim-roi.md)

Contenido: Hoja cálculo automatizada para análisis respuestas

Hojas Excel:

1. **Datos Brutos:** Importar respuestas encuesta
2. **Análisis IGM:** Cálculo automático madurez general + por bloque
3. **Brecha Normativa:** % conformidad NIS2/ENS/ISO
4. **ROI Salvaguardas:** Análisis financiero inversiones (FAIR/ALE)
5. **KPIs Ejecutivos:** Dashboard 1-página para Junta
6. **Referencias:** Tablas lookup, constantes, validación

Salidas principales:

IGM Global: 62% (L3 Repetible)
Target 12m: 75% (L4 Gestionado)
Gap: 13 puntos

Brecha NIS2:

- Art 21(a) Análisis Riesgos: 50% (MODERADO)
- Art 21(h) Continuidad: 20% (CRÍTICO)
- Art 21(g) Incidentes: 33% (CRÍTICO)

ROI Inversiones (Top 5):

1. SIEM: €50K inversión, €364K ALE reducción/año, Payback 1,6m
2. RTO/RPO: €75K inversión, €140K ALE reducción/año, Payback 6,4m
3. SOC 24/7: €120K/año, €70K ALE reducción/año, Payback 20m

Compatibilidad: Excel 2016+, Google Sheets, Números (parcial)

Macros: VBA opcional para automatización avanzada

6. TEMPLATE REPORTE EJECUTIVO (06-template-reporte-ppt.md)

Contenido: Estructura documento ejecutivo para Junta Directiva

Secciones (10-15 páginas):

1. **Portada** (1 pág): Título, fecha, confidencial
2. **Executive Summary** (1 pág): IGM, hallazgos clave, riesgos, top 5 acciones
3. **Contexto** (1 pág): Metodología, scope, limitaciones
4. **Resultados IGM** (2 pág): Madurez general + por bloque, gráficos
5. **Brecha Normativa** (2 pág): NIS2/ENS/ISO conformidad, heatmap
6. **Análisis Financiero** (1 pág): ALE, ROI, presupuesto recomendado
7. **Plan Acción** (1 pág): Top 10 mejoras, timeline, propietario, €
8. **Detalle Técnico** (3-4 pág): Deep-dive por bloque, hallazgos específicos
9. **Apéndices** (2-3 pág): Benchmark, metodología, contactos

Visualizaciones incluidas:

- Gauge IGM 0-100% (actual vs. target)
- Radar NIST 5 funciones (Identify, Protect, Detect, Respond, Recover)
- Heatmap Brecha Normativa (requisitos × % conformidad)
- Bubble Chart ROI (costo vs. impacto vs. plazo)
- Tabla Top 5-10 Acciones (presupuesto, timeline, propietario)

Tono: Profesional, propositivo, no alarmista

Audiencia: C-Suite, Junta Directiva

Duración presentación: 30-45 minutos

7. README KIT (Este archivo)

Contenido:

- Descripción general del kit
- Roadmap de uso rápido

- Preguntas frecuentes
- Contacto y soporte

ROADMAP DE USO RÁPIDO (Flujo Recomendado)

Fase 1: Preparación (Día 1, 2 horas)

1. Descargar 7 archivos .md
2. Leer README (este archivo) - 15 min
3. Leer Narrativa Explicativa (03) - 20 min → Entender fundamentos
4. Revisar Guía Metodológica (02) sección 2 - 15 min → Plan administración
5. Identificar respondentes + calendario - 30 min

Deliverable: Equipo preparado, calendario confirmado

Fase 2: Encuesta (Día 2-5, 2 horas)

6. Realizar briefing 30 min (explicar escala L1-L5, propósito)
7. Respondentes rellenan encuesta (45-60 min)
8. Opción A: Digital (Google Forms) + recopilación automática
9. Opción B: Sesión colaborativa 4h (CISO + equipo, facilitador)
10. Opción C: Mixta (individual 3 días + síntesis 90 min)
11. Validar respuestas completitud

Deliverable: 75 respuestas cumplimentadas

Fase 3: Análisis (Día 6-7, 2,5 horas)

12. Exportar respuestas a Excel (template 05)
13. Cálculos automáticos:
14. IGM general + por bloque
15. Brecha normativa
16. Análisis ROI (inputs histórico incidentes + benchmarking FAIR)
17. Generar gráficos (dashboard KPIs)
18. Redactar reporte ejecutivo (template 06)

Deliverable: Documento informe ejecutivo (10-15 pág) + Excel análisis

Fase 4: Feedback (Día 8, 2 horas)

19. Sesión presentación 30 min (CISO + CFO + Junta si aplica)
20. Q&A y aclaraciones 20 min
21. Workshop colaborativo 60 min → Priorizar top 10 acciones
22. Asignar propietarios, presupuesto, hitos

Deliverable: Plan de acción formalizado + RACI

Fase 5: Seguimiento (Continuado)

- Mensual: Seguimiento % plan acción completado
- Trimestral: Mini-assessment (15-20 preguntas clave)
- Anual: Re-evaluación completa (encuesta 75 preguntas)

Deliverable: Dashboard trending madurez (IGM año a año)

PREGUNTAS FRECUENTES (FAQ)

¿Cuánto cuesta implementar este kit?

Opción A: DIY (Gratis)

- Descargar archivos (0 €)
- CISO + equipo ejecutan (tiempo interno: ~15h)
- Costo oportunidad: ~€7.500 (15h × €500/h senior)

Opción B: Con consultoría externa (€15K-€30K)

- Facilitador externo 50h
- Análisis especializado, benchmarking
- Presentación ejecutiva profesional

Opción C: SaaS platform (€5K-€15K/año)

- Encuesta alojada en plataforma
- Análisis automático
- Benchmarking continuo
- Pero: Menos personalizable que DIY + consultor

¿Es obligatoria la encuesta para cumplir NIS2?

No obligatoria formalmente, pero **altamente recomendada**:

- NIS2 requiere "análisis riesgos formal" (Art 21a) = MAGERIT MAR
- Encuesta operacionaliza MAGERIT de forma estructurada
- Auditor externo solicita evidencia análisis riesgos = documentos encuesta + informe

Conclusión: No es legal requirement, pero es best practice para auditoría.

¿Qué diferencia hay con encuestas otras (Gartner, KPMG, etc.)?

Aspecto	Nuestro Kit	Gartner	KPMG
Precio	Gratis	€50-100K	€30-50K
Customización	Máxima (Markdown)	Fija	Media
Frameworks	MAGERIT + NIS2 + NIST	NIST + ISO	ISO + FAIR
ROI/FAIR	Sí, incluido	Opcional	Sí, incluido
Reporte	DIY (template)	Profesional	Profesional
Benchmark	Manual vs. benchmark nacional	Gartner MQ	KPMG pares
Timeline	1 semana	2-3 meses	3-6 semanas

Ventaja nuestro kit: Gratuito, flexible, alineado regulación española.

Desventaja: Requiere esfuerzo interno, benchmark manual.

¿Puedo adaptar las preguntas para mi sector (ej. Sanidad, Finanzas)?

Sí. Recomendaciones:

- Mantener estructura base (10 bloques, 75 preguntas)
- Adaptar en secciones:
 - Bloque 7 (Resiliencia): **Sanidad** añadir RTO <15min (crítico emergencias)
 - Bloque 3 (Métricas): **Finanzas** especificar CVSS + cumplimiento regulatorio
 - Bloque 4 (Vulnerabilidades): **Energía/ICS** añadir pruebas OT/SCADA
- Crear version "sector-specific" documento palabra clave

Ej.: 01-encuesta-integral-SANIDAD-v2.md con ajustes personalizados

¿Con qué frecuencia debo repetir la encuesta?

Recomendación:

- Completa (75 preguntas):** Anual (Q1 o Q4)
- Mini-assessment (20 preguntas):** Trimestral (bloques críticos: MAR, SIEM, Incidentes)
- Ad-hoc:** Post-incidente o cambio legislativo significativo

Rationale: Detectar tendencias, validar plan acción, adaptar a nuevas amenazas.

¿Qué hago si respondentes dan respuestas muy diferentes (ej. CISO L4 SIEM, TI L1)?

- Análisis: Discrepancia es dato válido. Indica desalineación interno.
- Sesión clarificación: CISO + TI revisar preguntas específicas (5.1-5.4)
- Consenso: Revisar evidencia (demo SIEM, logs, alertas reales)
- Ajuste: Usar media respuestas para análisis, pero registrar observación cualitativa
- Acción: "Alinear percepción seguridad SIEM entre liderazgo" → plan mejora

Conclusión: No es problema, es oportunidad identificar gaps comunicación.

¿Cómo calculo ALE/ROI si no tengo histórico incidentes?

Opciones:

1. **Benchmarking sectorial:** Usar tasas INCIBE (España: ~1,5 incidentes/año por empresa promedio)
2. **FAIR simulación:** Expertos opinión (TEF estimada, LM comparable sector)
3. **Conservative:** Asumir TEF baja, LM moderada → ALE mínimo
4. **Expert panel:** 3 expertos estiman por votación, media ponderada

Recomendación: Combinar benchmarking + expert opinion, documentar supuestos.

¿A quién contacto si tengo dudas técnicas del kit?

Opciones:

1. **Comunidad:** Consultar Observatorio ISMS Forum (ismsforum.es)
2. **Oficial:** CCN-CERT (ccn-cert.cni.es) para dudas MAGERIT
3. **Consultoría:** Buscar consultor ciberseguridad acreditado NIS2
4. **Este kit:** Referencia "README Kit MAGERIT-NIS2-ENS v2.0"

HOJA DE RUTA: PRÓXIMAS VERSIONES

Kit v2.0 (Actual, Enero 2026):

-  75 preguntas, 10 bloques, mapeo NIS2/ENS/ISO
-  Encuesta Markdown descargable
-  Excel análisis IGM + ROI
-  Template reporte ejecutivo

Kit v2.1 (Planificado, Q2 2026):

-  Integración feed threat intelligence (MITRE ATT&CK contexto España)
-  Benchmarking INCIBE 46 métricas ciberresiliencia
-  Versiones sector-específicas (Sanidad, Finanzas, Energía, Transporte)

Kit v3.0 (Planificado, Q4 2026):

-  Plataforma SaaS web (encuesta digital + análisis automático)
-  Integración SIEM para evaluación continua
-  Benchmark público comparativa pares

TÉRMINOS DE USO

Licencia: Creative Commons Attribution 4.0 (CC-BY-4.0)

Libertad: Descargar, modificar, distribuir (con atribución)

Prohibido: Uso comercial directo sin licencia específica

Soporte: Comunidad, sin garantía SLA

Referencia correcta:

"Kit Encuesta Integral Ciberseguridad MAGERIT-NIS2-ENS v2.0,
Consortio Científicos de Datos y Estrategas de Ciberseguridad,
España, Enero 2026"

CONTACTO Y FEEDBACK

¿Encontraste un error o mejora?

- Reportar en: [wiki comunitaria ISMS Forum]
- O enviar feedback: [correo contacto futuro]

¿Usas el kit exitosamente?

- Compartir caso de uso anónimo
- Mejorar futuras versiones con aprendizajes

¿Necesitas consultoría?

- Buscar "Auditoría NIS2 España" en Google
- Consultores especializados disponibles

CHECKLIST: ¿ESTÁS LISTO?

Antes de empezar encuesta:

- ☐ Descargar 7 archivos (.md)
- ☐ Leer Guía Metodológica (02) sección 2
- ☐ Identificar 3-5 respondentes (CISO, TI, Legal, RR.HH.)
- ☐ Reservar calendario: 1 semana mínimo
- ☐ Preparar herramienta: Google Forms o Excel
- ☐ Descargar template Excel (05) para análisis
- ☐ Revisar template reporte (06) para presentación

Durante encuesta:

- ☐ Realizar briefing 30 min
- ☐ Responder honestamente (no aspiracional)
- ☐ Añadir observaciones contexto crítico
- ☐ Validar completitud respuestas

Después encuesta:

- ☐ Analizar en Excel (IGM, brecha normativa, ROI)
- ☐ Generar informe ejecutivo
- ☐ Presentar a Junta Directiva
- ☐ Construir plan acción colaborativo
- ☐ Asignar propietarios, hitos, presupuesto

CONCLUSIÓN

Este kit es **herramienta profesional gratuita** para evaluar ciberseguridad bajo marcos regulatorios españoles (MAGERIT, ENS) e internacionales (NIS2, NIST, ISO 27001).

Objetivo: Convertir evaluación técnica compleja en **diagnóstico accionable** con lenguaje ejecutivo (€, ROI, madurez CMM).

Éxito se mide por:

1.  Encuesta completada honestamente
2.  IGM calculado y brecha identificada
3.  Plan acción priorizado y presupuestado
4.  Mejoras implementadas en 6-12 meses
5.  Re-evaluación anual demostrando progreso

Comienza hoy. Tu organización lo agradecerá.

© 2026 Kit Integral Encuesta Ciberseguridad MAGERIT-NIS2-ENS

**Consorcio de Científicos de Datos y Estrategas de Ciberseguridad, Resiliencia Digital y
Continuidad de Negocio**

Versión 2.0 | Enero 2026 | España | Creative Commons CC-BY-4.0

Documentos descargables incluidos:

1.  01-encuesta-integral.md (75 preguntas)
2.  02-guia-metodologica.md (administración)
3.  03-narrativa-explicativa.md (fundamentos)
4.  04-mapeo-normativo.md (conformidad)
5.  05-template-gim-roi.md (análisis Excel)
6.  06-template-reporte-ppt.md (ejecutivo)
7.  07-readme-kit.md (este archivo)

¡Comienza descargando todos los archivos ahora!